PROJECT DOCUMENTATION

03

Cloudflare Configuration and Change Report

The account, zone, Worker, D1 database, DNS and edge services behind rishavprasad.in, with the changes made during this engagement and the items left for the owner.

PREPARED FOR
Rishav Prasad
Owner and maintainer

SITE
rishavprasad.in
Cloudflare Workers

VERSION
1.0

DATE
31 October 2026

Contents

Cloudflare Configuration and Change Report · version 1.0 · 13 sections

01 Scope, evidence and method 3

02 Account and zone inventory 3

03 Public DNS records 4

04 TLS and HTTPS behaviour 5

05 Worker deployment inventory 6

06 Static Assets and routing 7

07 D1 database 8

08 Worker secrets 9

09 Turnstile and bot protection 9

10 R2, analytics and Pages 10

11 Change report for this engagement 10

12 Follow-ups and residual risks 11

13 Verification commands 12

01

Scope, evidence and method

This report records the Cloudflare configuration as it was observed on 31 October 2026. It separates what was verified directly, what was read from the repository, and what could not be verified with the credentials available.

What this document covers

- The Cloudflare account and the `rishavprasad.in` zone.
- Public DNS records, DNSSEC and email authentication records.
- TLS, HTTPS behaviour and the security headers the site emits.
- The `rishav-portfolio` Worker, its ten recorded deployments and its Static Assets routing.
- The `rishav-portfolio` D1 database, its eight tables and current row counts.
- Worker secret names, Turnstile, R2, Web Analytics and Cloudflare Pages.
- The change report for this engagement and the follow-ups that remain.

Evidence sources

SOURCE	WHAT IT ESTABLISHED	RELIABILITY
Wrangler 4.156.0 with the owner's OAuth login	Worker name, deployment list, versions, D1 metadata, secret names, R2 status.	Authoritative for the account
Public DNS-over-HTTPS (Cloudflare resolver)	A, AAAA, NS, DS, MX, TXT, CAA and DMARC answers.	Authoritative public view
HTTP requests to the production domain	Status codes, redirects, response headers, health endpoint, 404 handling.	Observed at the edge
TLS handshake to port 443	Certificate issuer, validity window and subject alternative names.	Observed at the edge
Repository files and git history	Intended configuration, bindings, routes and commit order.	Authoritative for code

Observation window: 31 October 2026, 07:00–07:30 UTC. Values such as row counts and deployment lists will drift; re-run the commands in section 13 before relying on them later.

> **Read-only engagement.** No Cloudflare dashboard setting, DNS record, secret value, Turnstile configuration or billing setting was changed during this engagement. The only changes were code commits deployed through the existing GitHub Actions pipeline, listed in section 12.

02

Account and zone inventory

The domain is active on a single Cloudflare account. The zone is served entirely by Cloudflare nameservers, and the apex is attached to a Worker as a custom domain.

OBJECT	IDENTIFIER OR VALUE	NOTES
Cloudflare account	`7d1e1101…187d16`	Single account used for all objects below.
Zone	`rishavprasad.in`	Active; no subdomains are used as separate sites.
Authoritative nameservers	`alla.ns.cloudflare.com` `koa.ns.cloudflare.com`	Both answers returned by the public resolver.
Worker	`rishav-portfolio`	Serves the API and proxies static assets.
Worker route	`rishavprasad.in` (custom domain)	Declared in `wrangler.jsonc`.
D1 database	`rishav-portfolio` `e3c63392-6892-402f-8bdd-70b379fbc664`	Primary region APAC; created 30 Oct 2026.
R2 bucket	None	R2 is not enabled on the account.
Turnstile widget	Site key `0x4AAAAAAFtJIYxwdn-xwScV`	Public key; rendered on the contact page.
Cloudflare Pages	Not used	Deployment is a Worker with Static Assets.

The account identifier is truncated deliberately. It is not a credential, but the full value is unnecessary in a handover document.

How the objects fit together

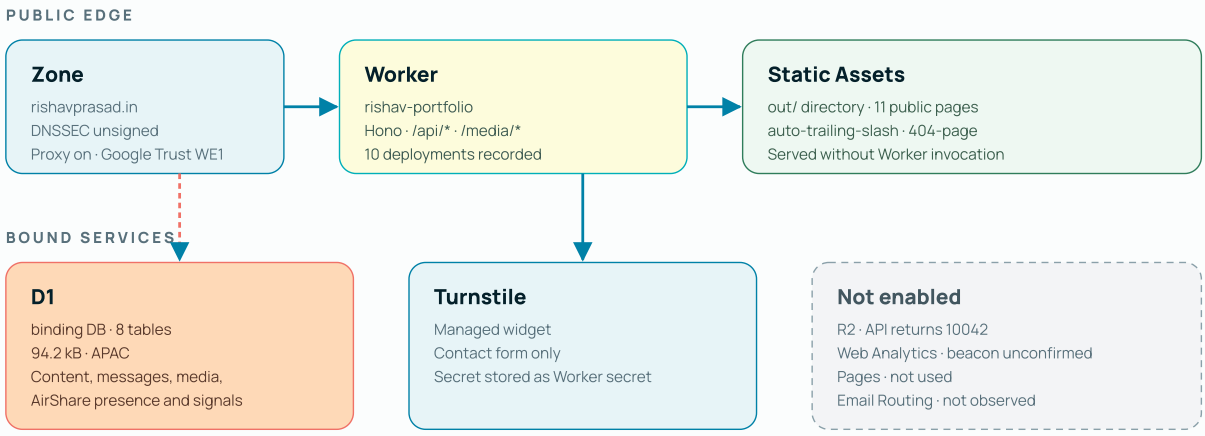


Figure 3.1 — Cloudflare objects in use. Solid lines are active request paths; the dashed line is a binding used by the Worker at request time.

03

Public DNS records

Only the apex and `www` resolve. The apex is proxied through Cloudflare; the nameservers are Cloudflare's. There is no mail infrastructure on the domain.

NAME	TYPE	VALUE OBSERVED	INTERPRETATION
`rishavprasad.in`	NS	`alla.ns.cloudflare.com` `koa.ns.cloudflare.com`	Zone delegated to Cloudflare.
`rishavprasad.in`	A	`104.21.3.214` `172.67.131.55`	Cloudflare anycast addresses; proxy enabled.
`rishavprasad.in`	AAAA	`2606:4700:3037::6815:3d6` `2606:4700:3037::ac43:8337`	IPv6 supported at the edge.
`www.rishavprasad.in`	A	Same two anycast addresses	Resolves, then redirects to the apex (section 05).
`rishavprasad.in`	MX	None	No mailbox on the domain.
`rishavprasad.in`	TXT	None returned	No SPF record and no site-verification TXT record at the apex.
`rishavprasad.in`	CAA	None	No certificate-authority restriction.
`_dmarc.rishavprasad.in`	TXT	`v=DMARC1; p=quarantine; adkim=r; aspf=r; rua=mailto:dmarc_rua@onsecureserver.net;`	DMARC policy exists, pointing reports at a third-party mailbox.
`rishavprasad.in`	DS	None	DNSSEC is not enabled; the resolver cannot authenticate the zone.

Queried with DNS-over-HTTPS against `cloudflare-dns.com`. Negative answers were confirmed by the absence of an Answer section.

What the DNS picture means

- **No email is configured.** There is no MX record and no SPF record, yet a DMARC record with `p=quarantine` exists. Any mail claiming to be from the domain has no SPF pass path and will be quarantined; this is harmless for the website but inconsistent if email is ever added.
- **No DNSSEC.** The zone is not signed, so there is no DS record. Enabling DNSSEC is a one-click operation in the dashboard but requires care if the domain's registrar is changed later.
- **No CAA pinning.** Certificate issuance is not restricted to an authority. Cloudflare currently issues through Google Trust Services (`WE1`).
- **The registrar's nameservers are no longer authoritative.** The resolver's authority section points at Cloudflare, which is expected for an active zone.

04

TLS and HTTPS behaviour

HTTPS is served with a Cloudflare-managed edge certificate. Plain HTTP is still answered, which means the zone-level "Always Use HTTPS" behaviour is not enforced.

CHECK	RESULT ON 31 OCT 2026	ASSESSMENT
Certificate issuer	Google Trust Services, `WE1`	Cloudflare-managed, publicly trusted.
Validity	30 Oct 2026 → 28 Jan 2027	Auto-renewed by Cloudflare; no action needed.
Subject alternative names	`rishavprasad.in`, `*.rishavprasad.in`	Wildcard covers `www` and future subdomains.
HSTS	`max-age=31536000; includeSubDomains`	Emitted by the Worker's headers. No `preload` directive.
`http://rishavprasad.in/`	`200`, no redirect	Plain HTTP is served; HSTS protects returning browsers only.
`https://www.rishavprasad.in/`	`301` → `https://rishavprasad.in/`	Canonical host; good for SEO.
Unknown path	`404` with the custom page	Correct status, not a soft 404.
IPv6	AAAA answers present	Dual-stack at the edge.

Residual risk: plain HTTP. Because "Always Use HTTPS" is not enforcing a redirect at the edge, a first-time visitor typing the bare domain over HTTP gets the site over HTTP. The Worker does not redirect either. Enabling "Always Use HTTPS" in SSL/TLS → Edge Certificates closes this without a code change. This was left untouched because it is a zone setting, outside the read-only scope of this engagement.

Security headers observed on the document response

```
content-security-policy: default-src 'self'; script-src 'self' 'unsafe-inline'
  https://challenges.cloudflare.com https://static.cloudflareinsights.com;
  style-src 'self' 'unsafe-inline'; img-src 'self' data:
  https://challenges.cloudflare.com; font-src 'self';
  connect-src 'self' blob: https://challenges.cloudflare.com
  https://cloudflareinsights.com;
  frame-src https://challenges.cloudflare.com; object-src 'none';
  base-uri 'self'; form-action 'self'; frame-ancestors 'none'
strict-transport-security: max-age=31536000; includeSubDomains
x-frame-options: DENY
x-content-type-options: nosniff
referrer-policy: strict-origin-when-cross-origin
permissions-policy: camera=(), microphone=(), geolocation=()
```

Headers are defined in `public/_headers` and served for static assets; `/api/*` responses add their own CORS and cache headers in the Worker.

05

Worker deployment inventory

Ten deployments are recorded for `rishav-portfolio`, all on 30–31 October 2026. Each is a full version at 100% traffic; there are no gradual rollouts, tags or deployment messages.

#	DEPLOYED (UTC)	VERSION IDENTIFIER	CORRESPONDING WORK
1	30 Oct 21:31:16	`b707bf4e…`	Admin sign-in fix (PBKDF2 at the Workers iteration ceiling).
2	30 Oct 21:35:35	`89ae00d0…`	Redeploy of the same fix window (documentation commit).
3	30 Oct 21:52:10	`0422a27a…`	Admin hash setup guidance; no application change.
4	30 Oct 21:55:20	`efdbf309…`	Redeploy after the documentation commit.
5	30 Oct 22:08:20	`0f7ad387…`	Resume upload hidden when R2 is unavailable.
6	30 Oct 22:09:42	`3499c21b…`	Content publish from the dashboard (content snapshot refresh).
7	30 Oct 22:17:12	`3f5c888d…`	Content snapshot after the D1 document update at 22:16:27.
8	30 Oct 22:23:52	`1f81607f…`	Resume/R2 guidance and deploy retry.
9	31 Oct 00:03:29	`ffa150ee…`	Audit hardening: headers and admin read paths.
10	31 Oct 00:11:13	`5552d11a…`	CSP updated to allow the Cloudflare Web Analytics beacon.

Source: `npx wrangler deployments list --name rishav-portfolio`. Version identifiers are truncated; deployment messages are empty in Cloudflare, so the "corresponding work" column is inferred from commit times and was not read from the deployment record.

Current status

- Latest deployment: **31 October 2026, 00:11:13 UTC**, version `5552d11a-bf31-44f5-8471-d1e223e76161` at 100%.
- Author recorded by Cloudflare: the owner's account email (omitted here), source "Unknown (deployment)" — consistent with `wrangler deploy` from CI using an API token.
- Compatibility date: `2026-10-01`, set in `wrangler.jsonc`.
- Health endpoint returns `{"ok":true,"service":"portfolio-api","database":"ok"}`, so the Worker and its D1 binding are live.

06

Static Assets and routing

The Worker is also the asset host. Cloudflare serves files from `out/` without invoking the Worker unless the path matches an API or media prefix.

SETTING	VALUE	EFFECT
`assets.directory`	`./out`	The Next.js static export produced by `npm run build`.
`assets.binding`	`ASSETS`	Available to the Worker for fallback and asset metadata.
`html_handling`	`auto-trailing-slash`	`/about` and `/about/` both resolve; canonical URLs use the trailing slash.
`not_found_handling`	`404-page`	Serves `404.html` with an HTTP 404 status.
`run_worker_first`	`/api/*`, `/media/*`	Only these prefixes invoke the Worker; everything else is a free static asset request.

SETTING	VALUE	EFFECT
`routes`	`{"pattern":"rishavprasad.in","custom_domain":true}`	Apex is the Worker's custom domain; the certificate covers it.
`vars.SITE_URL`	`https://rishavprasad.in`	Used for canonical URLs and the build-time content fetch.
`vars.GITHUB_REPO`	`Rishav0523/rishav-portfolio`	Target of the publish `repository_dispatch`.

> **Why this matters for cost and resilience.** Because pages are static assets, they do not consume Worker requests and remain available even if the Worker is failing. Only the contact form, admin API, content API and AirShare signalling reach the Worker.

07

D1 database

One D1 database holds every piece of mutable state: the content document, contact messages, the media index, login throttling records and AirShare signalling rows. Both migrations, `0001_init.sql` and `0002_airshare.sql`, were applied manually.

PROPERTY	VALUE
Database name / binding	`rishav-portfolio` / `DB`
Database identifier	`e3c63392-6892-402f-8bdd-70b379fbc664`
Created	30 October 2026, 19:47:22 UTC
Tables	8
Size	94.2 kB
Region	APAC (primary), read replication disabled
Last 24 h	5,759 reads, 526 writes, 18,061 rows read, 1,417 rows written
Content document	1 row, 8,767 bytes, updated 30 Oct 2026 22:16:27 UTC

Row counts at the time of audit

Counts taken 31 Oct 2026 07:15 UTC with `wrangler d1 execute … --remote`. The backup procedure is documented in document 05.

TABLE	ROWS	MEANING
`site_content`	1	The single published content document.
`contact_messages`	1	One message received on 31 Oct 2026; sender details withheld from this report.
`login_attempts`	1	One admin sign-in record, used for throttling.
`media`	0	No files uploaded; R2 is unavailable.
`airshare_peers`	1	Stale presence row from testing; expires by `last_seen` and has no user impact.
`airshare_signals`	0	Signals are deleted after delivery or expiry.
`airshare_join_attempts`	40	Join throttle records accumulated during testing.

Growth is negligible. Content is a single row; messages and login attempts are the only rows that accumulate. The free D1 limits are far above the current usage, and a backup strategy is documented in the deployment and recovery guide.

08

Worker secrets

Five secret names exist on the Worker. Values are not recorded anywhere in this repository or in this document.

SECRET NAME	PURPOSE	STATUS
`ADMIN_PASSWORD_HASH`	PBKDF2-SHA256 hash of the admin password, stored as `sha256:salt:hash`.	OWNER SUPPLIED
`SESSION_SECRET`	HMAC key for the signed admin session cookie.	OWNER SUPPLIED
`TURNSTILE_SECRET`	Server-side key for Turnstile `siteverify`.	IN USE
`GITHUB_TOKEN`	Fine-grained token used to trigger the deploy workflow on publish.	OWNER SUPPLIED
`0x4AAAAAAFtJI…` (redacted)	No code reads this name. Its name resembles a Turnstile key.	UNUSED

Action for the owner: remove the stray secret. The fifth secret's *name* is itself a Turnstile-style key. It is not referenced by `worker/env.ts` or any other file. Keeping it costs nothing but widens the credential surface. After confirming no external tool depends on it, delete it in the dashboard under Worker → Settings → Variables and Secrets.

Rotation

- `ADMIN_PASSWORD_HASH` — regenerate offline with the documented script, then replace the secret; existing sessions remain valid until the cookie expires (12 h) or `SESSION_SECRET` is rotated.
- `SESSION_SECRET` — rotating it invalidates every admin session immediately. Use 32 random bytes, base64-encoded.
- `GITHUB_TOKEN` — fine-grained, repository-scoped, expiring. Rotate in GitHub and Cloudflare together.
- `TURNSTILE_SECRET` — rotate in the Turnstile dashboard and update the Worker secret in the same sitting.

09

Turnstile and bot protection

The contact form is the only public write endpoint and the only place Turnstile is used. The widget's public site key appears in the contact page bundle; the secret is a Worker secret.

CONTROL	CONFIGURATION
Widget	Managed challenge, rendered client-side in the contact form.
Public site key	`0x4AAAAAAFtJIYxwdn-xwScV`
Server verification	`POST https://challenges.cloudflare.com/turnstile/v0/siteverify` from the Worker.
Failure behaviour	Submission rejected with a validation error; no row is written.
Additional limits	Field length caps, 5 submissions per hour per IP, and a honeypot-style timing check.
Admin protection	No Turnstile; PBKDF2 verification plus per-IP login throttling.
AirShare	No Turnstile; PIN-derived rooms and per-IP join limits.

> **Not exercised during the audit.** A failed-challenge path was not forced against production, because doing so would require disabling the widget or replaying a token. The rejection branch is covered by unit tests, not by a live negative test.

10

R2, analytics and Pages

R2 object storage

R2 is **not enabled** on the account. `wrangler r2 bucket list` fails with Cloudflare error `10042` ("Please enable R2 through the Cloudflare Dashboard"). The `MEDIA` binding is commented out of `wrangler.jsonc`; `/media/*` and media uploads return `503`, and the admin UI hides the upload control.

Enabling R2 would require: creating the bucket, uncommenting the binding, redeploying, and re-enabling the upload path in the admin UI. The resume page already points at the repository-hosted PDF so it does not depend on R2.

Cloudflare Web Analytics

The CSP was updated in commit `8c9ea09` to allow `static.cloudflareinsights.com` and `cloudflareinsights.com`. However, fetching the production HTML on 31 October 2026 returned no beacon script, including on a cache-bypassing request. The dashboard's Web Analytics state could not be re-read with the available token.

UNCONFIRMED Whether visits are being recorded. Check the Web Analytics dashboard for a non-zero visit count, or add the JavaScript snippet manually if the automatic injection is off.

Cloudflare Pages

Pages is not part of the deployment path. The site is a Worker with Static Assets, deployed by `wrangler deploy` from GitHub Actions. No `*.pages.dev` hostname was observed or relied upon.

11

Change report for this engagement

All changes were code changes reviewed and committed to `Rishav0523/rishav-portfolio`, then deployed by the existing workflow. No dashboard setting was modified.

COMMIT	CHANGE	REASON	DEPLOYED
`5f71a29`	Hash admin password at the Workers PBKDF2 ceiling (100,000 iterations).	Sign-in failed because the hash used an iteration count the runtime rejects.	30 Oct 21:31 UTC
`605ca6c`	Document setting the admin hash without a pipe.	A failed script piped into `wrangler secret put` stored an empty secret that reported as configured.	30 Oct 21:52 UTC
`7c37911`	Hide the resume upload when R2 is unavailable; point to the repository PDF.	R2 is not enabled; the upload control was a dead end.	30 Oct 22:08 UTC
`01faae7`	Harden headers and admin read paths found in the audit.	Security review findings.	31 Oct 00:03 UTC
`8c9ea09`	Allow the Web Analytics beacon in the CSP.	The beacon was blocked by `script-src` and `connect-src`.	31 Oct 00:11 UTC

What was deliberately not changed

- **DNS records** — apex and `www` already resolve correctly; no record was edited.
- **DNSSEC** — left unsigned; enabling it is a registrar-coordinated change and outside this scope.
- **Always Use HTTPS** — left off; enabling it is recommended but is a zone setting.
- **Secrets** — no value was created, read back or rotated; the stray secret is flagged for the owner.
- **Turnstile, R2, Analytics, Pages** — no configuration was created or modified.
- **Billing and plan** — untouched; the project stays on free-tier services.

12

Follow-ups and residual risks

ITEM	PRIORITY	ACTION
Stray Turnstile-style secret	High	Confirm unused, then delete in Worker → Settings → Variables and Secrets.
Always Use HTTPS	High	Enable in SSL/TLS → Edge Certificates.
DNSSEC	Medium	Enable in DNS → Settings; note the DS record if the registrar changes.
DMARC/SPF inconsistency	Medium	Either add a sending mail provider with SPF, or relax the DMARC record; today the domain sends no mail.
Web Analytics confirmation	Low	Check the dashboard for visits, or add the beacon snippet explicitly.
R2 (optional)	Low	Only if media uploads are wanted; requires enabling R2 and uncommenting the binding.
Certificate renewal	Low	Cloudflare-managed; verify the certificate is auto-renewed before 28 Jan 2027.

Verified healthy. DNS resolution, TLS, Worker routing, static asset delivery, the custom 404, the API health check and the D1 binding all responded correctly on 31 October 2026.

13

Verification commands

These are the exact commands used. Run them from the repository root with Wrangler authenticated as the account owner.

```
# Worker deployments and current version
npx wrangler deployments list --name rishav-portfolio
npx wrangler deployments status --name rishav-portfolio

# D1 metadata and row counts
npx wrangler d1 info rishav-portfolio
npx wrangler d1 execute rishav-portfolio --remote --json \
  --command "SELECT (SELECT COUNT(*) FROM contact_messages) AS messages,
   (SELECT COUNT(*) FROM site_content) AS content;"

# Secret names only — never prints values
npx wrangler secret list --name rishav-portfolio

# R2 status (expected to fail with 10042 while R2 is disabled)
npx wrangler r2 bucket list
```

```
# Public DNS: nameservers, DNSSEC, mail records
curl -s "https://cloudflare-dns.com/dns-query?name=rishavprasad.in&type=NS" \
  -H "accept: application/dns-json"
curl -s "https://cloudflare-dns.com/dns-query?name=rishavprasad.in&type=DS" \
  -H "accept: application/dns-json"
curl -s "https://cloudflare-dns.com/dns-query?name=_dmarc.rishavprasad.in&type=TXT" \
  -H "accept: application/dns-json"

# Edge behaviour and headers
curl -s -o /dev/null -w "%{http_code} %{redirect_url}\n" http://rishavprasad.in/
curl -s -o /dev/null -w "%{http_code} %{redirect_url}\n" https://www.rishavprasad.in/
curl -s https://rishavprasad.in/api/health
curl -sD - -o /dev/null https://rishavprasad.in/ | grep -i security
```

Record the date of any future run: deployment lists, certificate dates and row counts change. If a value conflicts with this report, the live command wins.